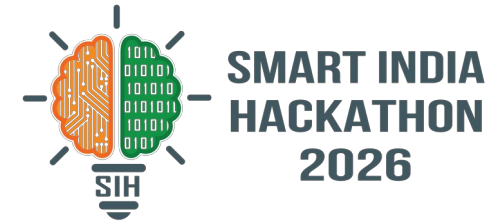


SMART INDIA HACKATHON 2026



TITLE PAGE

CryptoDrishti

An evidence-driven tool for discovering enterprise cryptography, assessing quantum exposure and planning post-quantum migration.

Problem Statement ID - SIH26164

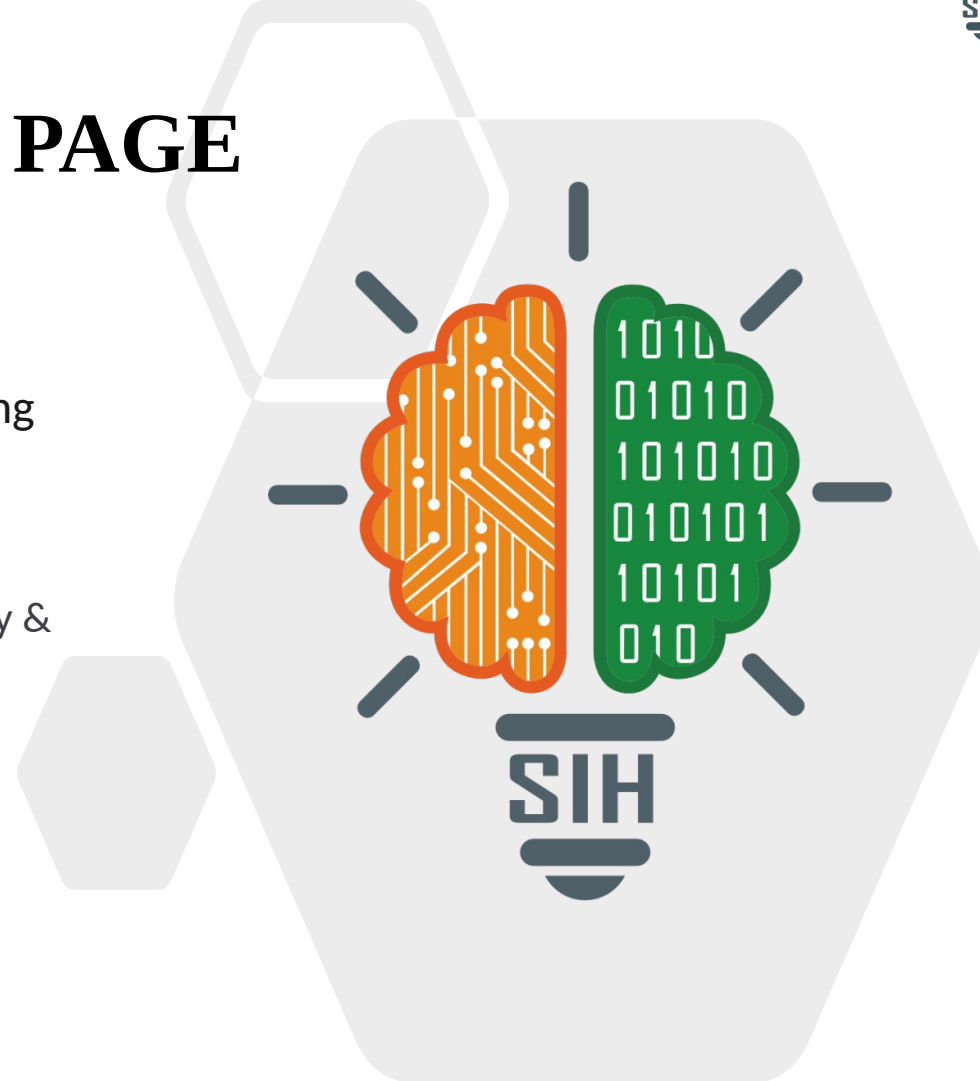
Problem Statement Title - Enterprise Cryptographic Discovery & Analysis Tool (ECDAT)

Theme - 26164

PS Category - Software

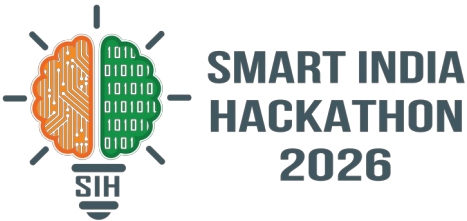
Team ID - 146876

Team Name - Zero-Day





CryptoDrishti | PROPOSED SOLUTION



The problem

Cryptographic assets are spread across application code, third-party libraries, configuration, certificates, compiled binaries and container images. Each records cryptography differently, and none of them is a list. Without a reliable inventory, an organisation cannot say which assets need quantum-safe migration, or in what order.

What CryptoDrishti is

CryptoDrishti discovers cryptographic evidence across those surfaces, normalises it into one inventory, assesses each asset's quantum exposure, and produces evidence-backed migration recommendations and a CycloneDX Cryptography Bill of Materials.

The implemented pipeline — every stage below exists in the tool.

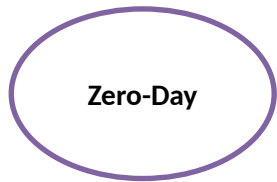


What it does

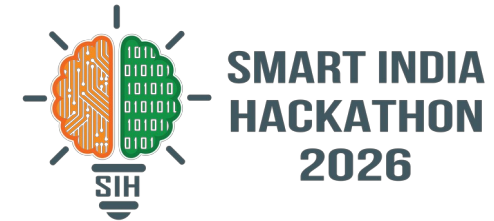
- **Multi-surface discovery** — seven sensors: code, dependencies, binaries, certificates, configuration, images, one named TLS endpoint
- **Purpose-aware classification** — an algorithm is classified by what it is used for, not by its name
- **Evidence assurance** — capability, declared, used and observed stay distinct grades
- **Per-asset risk prioritisation** — Mosca's inequality with operator-supplied asset context
- **Standards-conformant export** — CycloneDX 1.6 / 1.7, validated offline against the official schema

What makes it different

Finding RSA in a library is not observing RSA signing at a call site — capability, declaration, use and observation stay apart.



TECHNICAL APPROACH



System architecture

- Inputs — a directory, a container image archive, or a named TLS endpoint
- Seven sensors return evidence, not verdicts; hits become distinct assets carrying purpose and assurance
- Correlation links findings sharing an artefact, never merges them; a 74-algorithm registry classifies each
- Mosca $X + Y > Z$ read per purpose, then a named target, a CycloneDX CBOM and a traceable HTML report

Technical implementation

- **Backend / API** — Python 3.11+, FastAPI, uvicorn
- **Persistence** — SQLite (WAL) — scans, findings, overrides
- **Console** — vanilla JavaScript, 2,881 lines, no framework
- **Source scanning** — Python AST; 60 rules across 7 more languages
- **Dependencies** — 13 manifest formats, 22 known crypto libraries
- **Binaries** — ELF symbols — 72 symbols, 8 constants, 9 banners
- **Containers** — OCI, OCI tar, docker-save; layer replay
- **Export** — CycloneDX 1.6 / 1.7 with offline schema validation

One algorithm, three decisions. The same RSA, resolved three ways by a single scan.

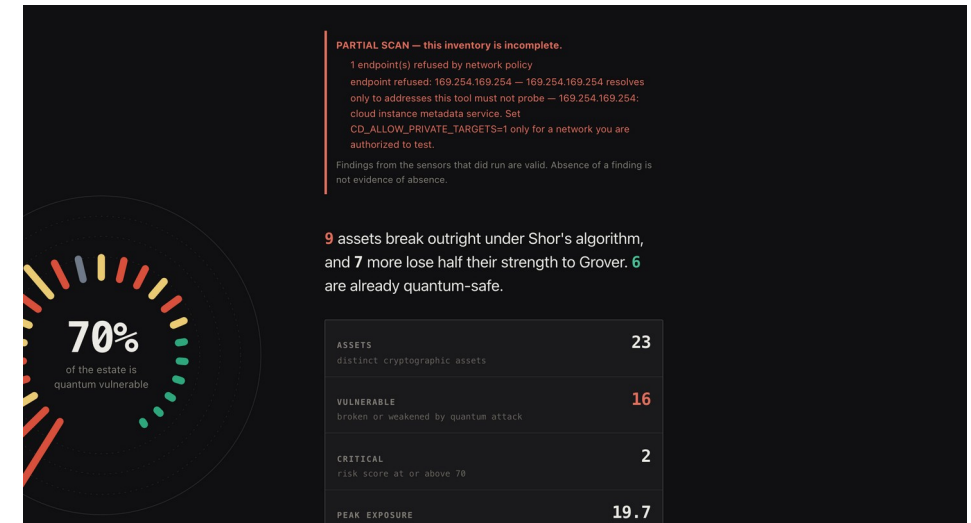
EVIDENCE	WHY THE PURPOSE RESOLVES THAT WAY	RECOMMENDATION	MEANING
Case 1 — RSA signing svc-payments/signing.py:15 (source · used)	RSA-PSS padding signs	ML-DSA-65	signature-oriented migration
Case 2 — RSA key establishment svc-gateway/transport.py:16 (source · used)	RSA-OAEP padding wraps a key	X25519MLKEM768	key-establishment migration
Case 3 — RSA, unresolved legacy/nginx.conf:5 (config · declared)	a cipher list permits RSA, purpose unstated	<i>Purpose must be resolved first</i>	further evidence required
Security design — operator-named targets only, every resolved address vetted first; local-first with nothing written to disk; partial scans disclosed and exported evidence redacted.			

Implemented prototype

- Seven scanning surfaces, each returning evidence with a location, a technique and a confidence
- An inventory of distinct assets, carrying purpose and assurance on every one
- A quantum-risk model taking operator-supplied shelf life, criticality and constraints, saved per asset and surviving a rescan
- Interactive investigation: filters, an evidence drawer, scan history
- CycloneDX 1.6 / 1.7 export and a self-contained HTML report reaching every finding

Validation

- **664 automated tests** — on Python 3.11, 3.12 and 3.13 in CI
- **Official schema validation** — every CBOM checked offline against the CycloneDX schemas at pinned commit 0bd48c8; CI fails on a violation
- **Hand-labelled benchmark** — 116 findings over six scanners, labelled from the fixtures, not from the tool's output
- **A test per defect found** — the benchmark caught seven detector defects code review had missed



Live console, demo estate — the partial-scan warning names the refused endpoint, above the real counts.

Why deployment is feasible — The tool is local-first: one machine, loopback by default, no cloud service, and it validates its own output offline. Committed demo fixtures reproduce every figure in this deck with one command.

Current limits — Full AST analysis is Python only; seven further languages use rule packs, and Rust and Swift are recognised but effectively uncovered. Binary parsing is ELF only. No KMS, HSM, cloud or Kubernetes integration. A working prototype, not a deployed product.

How a migration team actually uses the output

DISCOVER Build an inventory of the cryptographic assets present across the supported surfaces.

UNDERSTAND For each asset: the algorithm, the purpose it serves, how strong the evidence is, and exactly where it lives.

PRIORITISE Assess quantum exposure with documented assumptions and operator-supplied asset context, so the order of work is defensible.

PLAN Attach a purpose-appropriate migration target — or record that more evidence is needed before one can be chosen.

EXPORT Produce a schema-validated CBOM and a traceable report that another team or tool can consume.

Intended users

Intended for security engineering teams, cryptographic inventory and migration-planning teams, and infrastructure operators. These are intended users; the tool has not been deployed in production.

Benchmark evidence

Like-for-like: the same corpus, before and after

Baseline: 79 TP · 5 FP · 5 FN **F1 0.941**

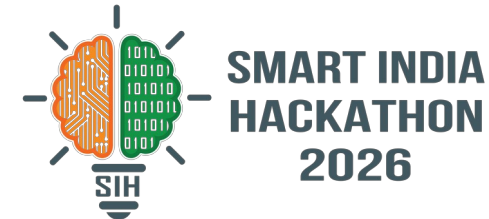
After detector fixes: 84 TP · 3 FP · 0 FN **F1 0.983**

Expanded synthetic corpus, six scanners

116 TP · 0 FP · 0 FN **F1 1.000**

Both corpora were created by the developers of this tool. These figures measure those corpora and nothing else — they are NOT an estimate of real-world enterprise accuracy, which has not been measured. The two experiments are not comparable to each other: the expanded corpus covers three scanners the original did not exercise.

RESEARCH AND REFERENCES



Cryptography standards informing classification and migration

- FIPS 203 — Module-Lattice-Based Key-Encapsulation Mechanism (ML-KEM). NIST, 2024. doi.org/10.6028/NIST.FIPS.203
- FIPS 204 — Module-Lattice-Based Digital Signature Standard (ML-DSA). NIST, 2024. doi.org/10.6028/NIST.FIPS.204
- FIPS 205 — Stateless Hash-Based Digital Signature Standard (SLH-DSA). NIST, 2024. doi.org/10.6028/NIST.FIPS.205
- NIST IR 8547 (initial public draft) — Transition to Post-Quantum Cryptography Standards. NIST, 2024.

Risk methodology

- M. Mosca, “Cybersecurity in an Era with Quantum Computers: Will We Be Ready?”, IEEE Security & Privacy, vol. 16, no. 5, 2018 — the source of the $X + Y > Z$ inequality used by the risk model.
- P. W. Shor, “Polynomial-Time Algorithms for Prime Factorization and Discrete Logarithms on a Quantum Computer”, SIAM J. Computing, 1997.
- L. K. Grover, “A fast quantum mechanical algorithm for database search”, STOC 1996 — the basis for the symmetric-key margin.

CBOM and container formats

- CycloneDX v1.6, standardised as ECMA-424 (1st edition, June 2024) — cyclonedx.org/specification/overview
- CycloneDX v1.7 JSON Schema. Both schemas vendored in this repository at pinned commit 0bd48c8 and checksummed.
- OCI Image Format Specification — image layout, manifests and layer whiteouts. github.com/opencontainers/image-spec
- RFC 8996 — Deprecating TLS 1.0 and TLS 1.1. rfc-editor.org/rfc/rfc8996

Problem statement and repository

- Smart India Hackathon 2026, Problem Statement SIH26164 — Enterprise Cryptographic Discovery & Analysis Tool (ECDAT), National Technical Research Organisation (NTRO).
- Source, 664 tests, the labelled benchmark corpus and its committed results, and the vendored schemas: github.com/sgtsujith141-wq/cryptodrishti

Scope of these references — CryptoDrishti discovers, classifies, assesses and recommends cryptography. It does not implement the post-quantum primitives above; it uses them as the standards that inform classification and migration targets.